



Un confronto tra standard ISO dedicati all'Ética dell'IA

di Stefano Gorla e Valeria Lazzaroli

Dipartimento AI Ethics

ENIA FONDAZIONE

Ente Nazionale per l'Intelligenza Artificiale



Un confronto tra standard ISO dedicati all'Etica dell'IA

di Stefano Gorla¹, Valeria Lazzaroli²

L'Intelligenza Artificiale rappresenta uno dei vettori di trasformazione più profondi e pervasivi del XXI secolo, non soltanto per la sua capacità di automatizzare processi o incrementare l'efficienza operativa, ma per il modo in cui riconfigura la natura stessa delle decisioni all'interno dei sistemi sociali, economici e istituzionali. A differenza delle precedenti ondate tecnologiche, l'IA non si limita a fornire strumenti di supporto all'azione umana, ma interviene direttamente nei meccanismi di selezione, classificazione, previsione e allocazione delle risorse, incidendo in modo strutturale su diritti, opportunità, responsabilità e rapporti di potere. In ambiti ad alta criticità come la sanità, la finanza, la pubblica amministrazione, le risorse umane, la sicurezza e l'industria, i sistemi di IA operano ormai come infrastrutture decisionali che orientano scelte con effetti reali e talvolta irreversibili su individui e collettività. La concessione di un credito, la priorità di una prestazione sanitaria, la selezione di un candidato, l'assegnazione di un rischio assicurativo o l'attivazione di un controllo di sicurezza non sono più esclusivamente il risultato di un giudizio umano, ma l'esito di processi ibridi

¹ Stefano Gorla, Dottore in Fisica, Auditor, Direttore del Dipartimento AI ETHICS di ENIA

² Valeria Lazzaroli, Psicologa, Sociologa, AI Manager, Lead Auditor ISO IEC 42001, Presidente ENIA



nei quali modelli algoritmici, dati storici e regole organizzative concorrono a produrre decisioni che assumono una forma sempre più opaca, distribuita e difficilmente attribuibile a un singolo attore. Questa trasformazione segna un passaggio epistemico rilevante perché l'IA non può più essere considerata un semplice artefatto tecnico, ma deve essere riconosciuta come un attore socio-tecnico, inserito in un ecosistema complesso di norme, valori, aspettative e responsabilità. In tale prospettiva, l'adozione dell'IA non è mai neutrale, poiché ogni sistema algoritmico incorpora implicitamente scelte normative, assunzioni valoriali e priorità organizzative che si riflettono sugli esiti prodotti. Il codice, i dati e l'architettura dei modelli diventano così luoghi di sedimentazione di decisioni che, pur apparendo tecniche, hanno una natura eminentemente politica ed etica. È proprio questa dimensione, spesso sottovalutata nelle prime fasi di diffusione dell'IA, ad aver reso evidente l'insufficienza di approcci puramente tecnologici o di compliance frammentata, fondati su controlli ex post o su adattamenti incrementali di norme preesistenti. L'integrazione dell'IA nei processi decisionali ha infatti messo in crisi categorie tradizionali del diritto, del risk management e della governance aziendale. Concetti come responsabilità, imputabilità, diligenza professionale e controllo assumono nuove configurazioni quando le decisioni sono mediate da modelli probabilistici, addestrati su grandi volumi di dati e capaci di

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



apprendere comportamenti emergenti non sempre pienamente prevedibili. La delega decisionale all'IA, anche quando parziale, produce una redistribuzione delle responsabilità che non può essere affrontata attraverso strumenti concettuali pensati per sistemi deterministici o per catene decisionali lineari. Ne consegue la necessità di ripensare la governance dell'IA come un dominio autonomo, dotato di propri principi, strumenti e meccanismi di controllo, in grado di tenere insieme innovazione tecnologica, tutela dei diritti fondamentali, fiducia degli stakeholder e sostenibilità organizzativa. In questo contesto si colloca l'emergere di due grandi famiglie di strumenti di regolazione dell'IA, profondamente diverse per natura giuridica ma complementari nella funzione. Da un lato, gli standard volontari internazionali sviluppati in ambito ISO/IEC, che forniscono cornici concettuali, linee guida operative e, in alcuni casi, veri e propri sistemi di gestione orientati alla governance dell'IA. Dall'altro, le regolamentazioni cogenti, tra cui spicca il Regolamento europeo sull'Intelligenza Artificiale, noto come AI Act, che introduce obblighi legali, classificazioni di rischio e meccanismi sanzionatori direttamente applicabili negli Stati membri. La coesistenza di questi due livelli di regolazione non rappresenta una duplicazione ridondante, ma riflette la complessità del fenomeno IA e la necessità di affrontarlo attraverso strumenti differenziati ma coordinati. Gli standard ISO/IEC si

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



collocano in una logica di soft law tecnica e organizzativa. Essi non impongono obblighi giuridici diretti, ma definiscono modelli di riferimento condivisi a livello internazionale, capaci di orientare le pratiche delle organizzazioni verso livelli più elevati di maturità, controllo e responsabilità. In particolare, gli standard di sistema introducono una logica di governance basata su processi, ruoli, responsabilità, valutazione dei rischi e miglioramento continuo, consentendo di trasformare principi astratti in pratiche verificabili. Questa dimensione è cruciale nel contesto dell'IA, dove l'assenza di strutture organizzative adeguate rappresenta uno dei principali fattori di rischio, spesso più rilevante delle caratteristiche tecniche dei singoli modelli. Le regolamentazioni cogenti, al contrario, rispondono all'esigenza di tutelare interessi pubblici fondamentali, come i diritti umani, la sicurezza e il corretto funzionamento del mercato. L'AI Act europeo introduce una classificazione dei sistemi di IA in base al livello di rischio e impone requisiti stringenti per quelli considerati ad alto rischio, incidendo direttamente sulle modalità di progettazione, sviluppo, implementazione e utilizzo. Tuttavia, la norma giuridica, per sua natura, definisce il “cosa” deve essere rispettato, ma difficilmente entra nel dettaglio del “come” le organizzazioni debbano strutturarsi per garantire un controllo effettivo e continuo dei sistemi di IA nel tempo. È proprio in questo spazio operativo che gli standard ISO/IEC trovano la loro funzione

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



strategica. L'integrazione tra standard volontari e regolamentazione cogente diventa dunque un elemento chiave per un'adozione consapevole dell'IA. Non si tratta di scegliere tra compliance legale ed eccellenza organizzativa, ma di riconoscere che la conformità normativa, soprattutto in un ambito dinamico e tecnologicamente complesso come quello dell'IA, non può essere raggiunta in modo sostenibile senza un adeguato sistema di governance. Gli standard ISO/IEC offrono alle organizzazioni un linguaggio comune, strumenti strutturati e meccanismi di audit che consentono di rendere dimostrabile ciò che il legislatore richiede in termini di controllo, responsabilità e gestione del rischio. In questo senso, la governance dell'IA si configura come un dominio ibrido, nel quale diritto, tecnica ed etica non operano come sfere separate, ma come dimensioni interdipendenti di un unico sistema socio-tecnico. Comprendere il ruolo e le differenze tra questi strumenti non è quindi un esercizio meramente teorico, ma una condizione necessaria per evitare approcci superficiali o meramente reattivi all'adozione dell'IA. Le organizzazioni che affrontano l'IA esclusivamente come un problema tecnologico tendono a sottovalutare gli impatti sistemici e a esporsi a rischi reputazionali, legali e operativi difficilmente governabili a posteriori. Al contrario, un approccio strutturato, fondato sull'integrazione tra standard di gestione e regolamentazione, consente di collocare l'IA all'interno di un quadro di decisione

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



consapevole, nel quale l'innovazione non è in opposizione alla responsabilità, ma ne diventa una componente essenziale. È in questa prospettiva che la governance dell'Intelligenza Artificiale deve essere letta non come un vincolo all'adozione tecnologica, ma come l'infrastruttura abilitante che rende possibile un uso dell'IA coerente con i valori democratici, la sostenibilità economica e la fiducia degli stakeholder, ponendo le basi per una trattazione sistematica dei modelli di gestione che verranno analizzati nei paragrafi successivi.

ISO 26000 – Responsabilità sociale come fondamento etico dell'IA

La norma ISO 26000, pubblicata dalla International Organization for Standardization³, rappresenta uno dei riferimenti più solidi e al tempo stesso più frastuonanti nel dibattito contemporaneo sulla governance dell'Intelligenza Artificiale. Nata come linea guida internazionale sulla responsabilità sociale delle organizzazioni, essa non si colloca nel perimetro delle norme certificabili, ma svolge una funzione più profonda e strutturale: fornire una grammatica etica condivisa per orientare le decisioni organizzative in contesti ad alta complessità e impatto sociale. Proprio questa natura non prescrittiva,

³ International Organization for Standardization. (2010). *ISO 26000: Guidance on social responsibility*. Geneva: International Organization for Standardization.



spesso letta come un limite in ambienti fortemente orientati alla compliance, costituisce in realtà il principale punto di forza della ISO 26000 nel contesto dell'IA. L'assenza di requisiti tecnici puntuali e di controlli formali non ne riduce la rilevanza, ma la rende una cornice epistemica capace di attraversare domini tecnologici diversi, anticipando questioni che la normazione tecnica e la regolazione giuridica tendono a intercettare solo in una fase successiva. In tal senso, la ISO 26000 opera come fondamento etico-culturale su cui possono innestarsi sistemi di gestione, controlli organizzativi e obblighi legali, fornendo un orientamento stabile in un contesto tecnologico intrinsecamente instabile. La distinzione tra norme certificabili e linee guida, centrale nell'architettura ISO, assume qui un significato particolare. Le norme di sistema, come ISO 9001⁴ o ISO/IEC 27001⁵, sono progettate per essere auditabili e certificabili, e dunque per rendere verificabile l'adozione di determinati processi e controlli. La ISO 26000, al contrario, non mira a dimostrare la conformità a requisiti specifici, ma a orientare il modo in cui un'organizzazione definisce le proprie responsabilità nei confronti della società. Questo scarto è particolarmente rilevante nel caso dell'IA, poiché molti dei

⁴ International Organization for Standardization. (2015). *ISO 9001:2015 – Quality management systems — Requirements*. Geneva: ISO.

⁵ International Organization for Standardization. (2022). *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*. Geneva: ISO.



rischi associati ai sistemi algoritmici non sono immediatamente riconducibili a violazioni formali, ma emergono come effetti sistemici di scelte organizzative, culturali e valoriali. L'adozione di un sistema di IA può risultare tecnicamente conforme e legalmente accettabile, pur producendo effetti discriminatori, opachi o socialmente dannosi. È in questo spazio grigio, tra ciò che è formalmente lecito e ciò che è eticamente sostenibile, che la ISO 26000 esercita la propria funzione più rilevante. I principi su cui la norma si fonda – responsabilità, trasparenza, comportamento etico, rispetto degli stakeholder, legalità, rispetto delle norme internazionali di comportamento e tutela dei diritti umani – assumono una valenza specifica quando applicati all'IA. La responsabilità, intesa come accountability, non può essere ridotta alla mera individuazione di un soggetto giuridico responsabile, ma richiede una riflessione sulla distribuzione delle decisioni tra esseri umani e sistemi automatizzati. In presenza di modelli che apprendono da dati storici, che operano su base probabilistica e che possono produrre risultati non pienamente prevedibili, l'accountability diventa una proprietà emergente del sistema organizzativo nel suo complesso, e non una qualità attribuibile a un singolo attore. La trasparenza, a sua volta, non coincide semplicemente con la disponibilità di informazioni tecniche, ma riguarda la capacità dell'organizzazione di spiegare, giustificare e rendere comprensibili le

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



decisioni automatizzate a coloro che ne subiscono gli effetti. Il comportamento etico non si esaurisce nel rispetto delle leggi vigenti, ma implica una valutazione preventiva degli impatti sociali e una disposizione attiva alla mitigazione dei rischi, anche quando questi non sono ancora codificati in obblighi normativi. Il rispetto degli interessi degli stakeholder assume, nel contesto dell'IA, una dimensione particolarmente articolata. I sistemi algoritmici incidono su una pluralità di soggetti, spesso non immediatamente visibili o rappresentati nei processi decisionali interni all'organizzazione. Utenti finali, cittadini, lavoratori, comunità locali e persino generazioni future possono essere influenzati da scelte tecnologiche apparentemente circoscritte. La ISO 26000 invita le organizzazioni a riconoscere questa pluralità di interessi e a integrare il dialogo con gli stakeholder come parte integrante della governance, superando una visione ristretta centrata esclusivamente su clienti e azionisti. Questo approccio risulta essenziale per l'IA, dove la distanza tra chi progetta, chi utilizza e chi subisce gli effetti dei sistemi può essere particolarmente ampia. La tutela dei diritti umani, esplicitamente richiamata dalla norma, rappresenta forse il punto di contatto più diretto tra ISO 26000 e il dibattito contemporaneo sull'IA. Sebbene la norma non menzioni specificamente i sistemi algoritmici, essa fornisce un quadro concettuale immediatamente applicabile a tecnologie che influenzano l'accesso a risorse, opportunità e servizi essenziali. L'IA

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



può incidere sul diritto alla non discriminazione, alla privacy, alla libertà di espressione, al lavoro e alla dignità personale, spesso in modo indiretto e mediato. La ISO 26000 consente di affrontare questi impatti non come eccezioni patologiche, ma come dimensioni strutturali dell'adozione tecnologica, richiedendo alle organizzazioni di valutare sistematicamente le conseguenze delle proprie scelte. In questo senso, la rilevanza della ISO 26000 per l'IA non risiede nella capacità di fornire soluzioni tecniche, ma nel suo ruolo di cornice etica di responsabilità. L'IA, pur essendo una tecnologia, produce effetti sociali, economici e ambientali che richiedono un governo consapevole. La norma consente di tematizzare questioni quali la supervisione umana delle decisioni automatizzate, la tracciabilità delle scelte algoritmiche, la prevenzione di discriminazioni basate su genere, età, origine etnica o condizioni di vulnerabilità, e la protezione della dignità umana in applicazioni particolarmente sensibili come la sorveglianza, il credit scoring o la selezione del personale. Questi aspetti, spesso affrontati in modo frammentario nei dibattiti tecnici, trovano nella ISO 26000 un principio di unificazione concettuale. Un ulteriore elemento di rilievo riguarda la dimensione organizzativa e lavorativa. L'adozione dell'IA modifica ruoli, competenze e condizioni di lavoro, introducendo nuove forme di controllo, valutazione e sorveglianza. La ISO 26000 invita a considerare questi impatti come parte integrante

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



della responsabilità sociale dell'organizzazione, sollecitando analisi preventive e politiche attive di reskilling e upskilling. In ambito HR, l'uso dell'IA pone questioni delicate in termini di equità, trasparenza e autonomia professionale, che non possono essere risolte esclusivamente attraverso requisiti tecnici o legali. La norma offre un orientamento per integrare l'IA in modo coerente con il rispetto delle persone, evitando derive strumentali o invasive. La responsabilità sociale si estende inoltre alla catena di fornitura digitale. I sistemi di IA sono spesso il risultato di ecosistemi complessi che coinvolgono fornitori di dati, sviluppatori di modelli, piattaforme cloud e integratori di sistema. La ISO 26000 consente di estendere l'attenzione etica oltre i confini dell'organizzazione, introducendo criteri di valutazione dei rischi sociali lungo la supply chain e sollecitando l'inclusione di clausole contrattuali relative all'uso lecito ed etico dell'IA. Questo aspetto assume un'importanza crescente in un contesto in cui la responsabilità tende a frammentarsi lungo catene globali di produzione tecnologica. Non meno rilevante è la dimensione ambientale. I modelli di IA, in particolare quelli di grandi dimensioni, comportano consumi energetici significativi e un impatto ambientale non trascurabile. La ISO 26000, attraverso il suo focus sulla sostenibilità, offre un quadro per integrare considerazioni ambientali nelle scelte tecnologiche, promuovendo l'efficienza, l'uso responsabile delle infrastrutture cloud e l'allineamento

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



dell'IA con le strategie ESG. Anche in questo caso, la norma non fornisce metriche tecniche, ma orienta il processo decisionale verso una valutazione sistemica degli impatti. Nel complesso, la ISO 26000 non governa il funzionamento interno dei sistemi di IA, ma definisce il modo in cui un'organizzazione dovrebbe decidere di adottarli, utilizzarli e controllarli. Essa prepara il terreno culturale e organizzativo su cui possono innestarsi norme tecniche più specifiche e sistemi di gestione certificabili, come quelli previsti dalla ISO/IEC 42001. In assenza di questa base etica, la governance dell'IA rischia di ridursi a un esercizio formale di compliance, incapace di intercettare i rischi emergenti e di costruire una fiducia duratura con gli stakeholder. La ISO 26000 svolge dunque una funzione essenziale nel quadro della governance dell'Intelligenza Artificiale: non come alternativa alla normazione tecnica o alla regolazione giuridica, ma come fondamento etico che consente di dare coerenza, profondità e legittimità alle scelte organizzative in un'epoca in cui la tecnologia è divenuta una delle principali forme di esercizio del potere decisionale.

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



ISO/IEC 24368 – Etica dell'IA by design

La norma ISO/IEC 24368⁶ si colloca in una posizione epistemicamente cruciale nel panorama della governance dell'Intelligenza Artificiale, poiché affronta uno dei nodi più complessi e spesso elusi del dibattito contemporaneo: la traduzione operativa dell'etica all'interno dei sistemi tecnici. Se la ISO 26000 fornisce una cornice valoriale e culturale che orienta le decisioni organizzative, la ISO/IEC 24368 assume il compito più delicato di rendere quei valori tecnicamente significativi, intervenendo direttamente nei processi di progettazione, sviluppo, addestramento, implementazione e monitoraggio dei sistemi di IA. In questa prospettiva, l'etica non è più concepita come un insieme di principi esterni o successivi alla tecnologia, ma come una proprietà emergente del sistema socio-tecnico nel suo complesso, che deve essere intenzionalmente incorporata nelle architetture, nei dati, nei modelli e nei processi decisionali. È qui che la norma esprime con maggiore chiarezza la propria affinità con una filosofia delle tecnologie di matrice informazionale, nella quale l'IA viene intesa come infrastruttura cognitiva che riorganizza l'ambiente decisionale, e non semplicemente come strumento neutro al servizio di fini predefiniti. La nozione di

⁶ International Organization for Standardization & International Electrotechnical Commission. (2024). *ISO/IEC 24368: Information technology — Artificial intelligence — Overview of ethical and societal concerns*. Geneva: International Organization for Standardization.



“etica by design”, centrale nella ISO/IEC 24368, non va interpretata come un’estensione metaforica di pratiche di design responsabile, ma come un preciso orientamento normativo che riconosce la natura intrinsecamente normativa dei sistemi di IA. Ogni scelta tecnica, dalla selezione delle variabili alla definizione delle funzioni obiettivo, dall’architettura del modello alle modalità di interazione con l’utente, implica una presa di posizione rispetto a ciò che viene considerato rilevante, desiderabile o accettabile. La norma parte dal presupposto che tali scelte non possano essere lasciate all’implicito o delegate esclusivamente alla competenza tecnica, ma debbano essere rese esplicite, discusse e governate all’interno di un quadro strutturato. In questo senso, la ISO/IEC 24368 non introduce nuovi valori etici, ma si concentra sul problema, eminentemente tecnico, di come valori già riconosciuti possano essere incorporati nei sistemi di IA senza perdere coerenza, tracciabilità e controllabilità. Lungo l’intero ciclo di vita dell’IA, la norma invita a considerare l’etica come una dimensione trasversale e persistente, che non può essere confinata a una fase specifica del processo. Nella progettazione, ciò implica una riflessione preventiva sugli scopi del sistema, sui contesti d’uso previsti e su quelli ragionevolmente prevedibili, nonché sugli impatti potenziali sugli individui e sui gruppi sociali coinvolti. In questa fase, l’etica by design si manifesta come capacità di anticipazione, ovvero come attitudine a interrogarsi sulle

FONDAZIONE
ENTE NAZIONALE per L’INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



conseguenze sistemiche delle scelte tecnologiche prima che esse si cristallizzino in soluzioni difficilmente reversibili. Dal punto di vista normotecnico, questo si traduce nella necessità di documentare le assunzioni progettuali, le alternative considerate e le motivazioni che hanno condotto a determinate decisioni, creando una base informativa che potrà essere successivamente oggetto di audit e revisione. Nella fase di sviluppo e addestramento, la ISO/IEC 24368 pone particolare attenzione al ruolo dei dati come veicolo primario di valori e bias. I dataset non sono semplici rappresentazioni neutre della realtà, ma riflettono strutture sociali, storie di esclusione e asimmetrie di potere che possono essere amplificate dai modelli di IA. La norma sollecita una valutazione sistematica dei rischi etici associati ai dati, includendo la provenienza, la qualità, la rappresentatività e le modalità di raccolta. In questa prospettiva, la prevenzione dei bias non è riducibile a un problema statistico, ma richiede una comprensione più ampia delle dinamiche sociali che i dati incorporano. La norma non prescrive tecniche specifiche di debiasing, ma richiede che le scelte adottate siano consapevoli, motivate e coerenti con i valori dichiarati dall'organizzazione. Ancora una volta, l'accento è posto sulla tracciabilità delle decisioni, più che sull'illusione di una neutralità algoritmica irraggiungibile. Durante l'implementazione, l'etica by design assume una dimensione relazionale. I sistemi di IA non operano nel vuoto, ma interagiscono con utenti,

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



operatori e altri sistemi, influenzando comportamenti e aspettative. La ISO/IEC 24368 invita a considerare l'esperienza dell'utente come parte integrante dell'architettura etica del sistema, ponendo attenzione alla comprensibilità, alla prevedibilità e alla possibilità di intervento umano. In questo senso, la spiegabilità non è intesa come mera trasparenza tecnica, ma come capacità del sistema di fornire informazioni significative e contestualizzate a coloro che ne subiscono gli effetti. La norma riconosce che non tutte le decisioni automatizzate possono essere completamente spiegate in termini semplici, ma richiede che l'organizzazione si interroghi su quali livelli di spiegazione siano appropriati in relazione ai rischi e agli impatti del sistema. La fase di monitoraggio rappresenta un ulteriore elemento distintivo dell'approccio della ISO/IEC 24368. L'etica dell'IA non è una proprietà statica, ma una qualità dinamica che può degradarsi nel tempo a causa di cambiamenti nei dati, nei contesti d'uso o nelle interazioni con altri sistemi. La norma sollecita quindi l'adozione di meccanismi di osservazione continua degli output e degli effetti del sistema, al fine di individuare deviazioni, effetti inattesi o impatti negativi emergenti. Dal punto di vista normotecnico, ciò implica la definizione di indicatori, soglie di attenzione e procedure di intervento che consentano di mantenere l'allineamento tra i valori dichiarati e il comportamento effettivo del sistema. In questa logica, l'etica by design si estende naturalmente in un'etica by



operation, che riconosce la necessità di un governo continuo dell'IA. Un aspetto particolarmente rilevante della ISO/IEC 24368 è la sua funzione di traduzione tra linguaggi disciplinari diversi. La norma è concepita per essere utilizzata da team multidisciplinari che includono sviluppatori, data scientist, decision maker e figure di governance. Essa fornisce un lessico comune che consente di discutere questioni etiche in termini operativi, evitando sia l'astrazione filosofica fine a se stessa sia il riduzionismo tecnico. In questo senso, la norma svolge un ruolo di mediazione epistemica, rendendo possibile un dialogo strutturato tra chi definisce i valori e chi costruisce i sistemi. Questa funzione è particolarmente importante in contesti organizzativi complessi, dove la distanza tra livelli decisionali e livelli operativi può generare incoerenze difficili da rilevare e correggere. La complementarità tra ISO/IEC 24368 e ISO 26000 emerge con chiarezza proprio in questa capacità di traduzione. Se la ISO 26000 risponde alla domanda “quali valori dovrebbero orientare l'azione dell'organizzazione”, la ISO/IEC 24368 affronta il problema di “come questi valori possano essere incorporati in sistemi tecnici concreti”. Essa non sostituisce la riflessione etica di alto livello, ma la rende praticabile all'interno dei processi di sviluppo dell'IA. Al tempo stesso, la norma prepara il terreno per l'adozione di un sistema di gestione strutturato, come quello previsto dalla ISO/IEC 42001, fornendo

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



criteri operativi che possono essere integrati in procedure, controlli e audit. In una prospettiva più ampia, la ISO/IEC 24368 contribuisce a ridefinire il rapporto tra etica e normazione tecnica. Tradizionalmente, l'etica è stata considerata un dominio esterno alla tecnica, affidato a codici di condotta o a comitati consultivi. La norma riconosce invece che, nel caso dell'IA, l'etica deve essere trattata come una dimensione progettuale, soggetta a scelte, trade-off e vincoli analoghi a quelli tecnici. Questo non significa ridurre l'etica a un problema ingegneristico, ma riconoscere che la sua efficacia dipende dalla capacità di essere incorporata in artefatti e processi concreti. In questo senso, la ISO/IEC 24368 rappresenta un passo significativo verso una governance dell'IA che non separa valori e tecnologia, ma li considera come elementi co- costitutivi di un unico sistema socio-tecnico. Nel contesto attuale, caratterizzato da una crescente attenzione regolatoria e da aspettative sociali sempre più elevate, la norma assume un valore strategico per le organizzazioni che intendono adottare l'IA in modo responsabile. Pur essendo una norma volontaria e non certificabile, essa offre un riferimento essenziale per dimostrare la diligenza organizzativa nella gestione dei rischi etici, anticipando requisiti che stanno progressivamente entrando nel perimetro delle regolamentazioni cogenti. In questo senso, la ISO/IEC 24368 non va letta come un'alternativa alla compliance legale, ma come un dispositivo di preparazione e

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



allineamento, capace di rendere l'etica dell'IA una componente strutturale e verificabile della governance organizzativa. Nel quadro complessivo della governance dell'Intelligenza Artificiale, la ISO/IEC 24368 svolge dunque una funzione di cerniera. Essa collega la dimensione valoriale della responsabilità sociale alla dimensione gestionale dei sistemi di IA, rendendo possibile un passaggio ordinato dall'etica come principio all'etica come pratica. È in questa funzione di traduzione e integrazione che la norma esprime il proprio contributo più rilevante, ponendo le basi per una successiva formalizzazione della governance dell'IA all'interno di sistemi di gestione certificabili. In tal modo, l'etica by design non si esaurisce in un auspicio, ma diventa una componente strutturale di un approccio normotecnico maturo, capace di sostenere l'adozione dell'IA in contesti ad alta complessità e responsabilità.

ISO/IEC 42001:2023 – Sistema di gestione dell'Intelligenza Artificiale

La ISO/IEC 42001⁷ rappresenta una svolta concettuale e operativa nel panorama della governance dell'Intelligenza Artificiale, poiché introduce per la prima volta un sistema di gestione certificabile specificamente dedicato all'IA, riconoscendo formalmente che

⁷ International Organization for Standardization & International Electrotechnical Commission. (2023). *ISO/IEC 42001 – Artificial intelligence management system*. Geneva: International Organization for Standardization.



essa non può essere governata come una tecnologia ordinaria. Con questo standard, l'IA viene definitivamente collocata all'interno della famiglia delle infrastrutture organizzative critiche, al pari della qualità, della sicurezza delle informazioni o della continuità operativa. La scelta di adottare la High Level Structure comune agli standard ISO di sistema non è meramente formale, ma riflette una precisa presa di posizione epistemica: l'IA non è un insieme di modelli isolati, bensì un insieme di processi, decisioni, responsabilità e controlli che devono essere integrati nel governo complessivo dell'organizzazione. In questa prospettiva, la norma riconosce che il rischio principale associato all'IA non risiede esclusivamente nelle prestazioni tecniche dei modelli, ma nella capacità dell'organizzazione di comprenderli, governarli e renderne conto nel tempo. La ISO/IEC 42001 opera un passaggio decisivo dalla dimensione dell'etica come principio alla dimensione della governance come pratica strutturata. Se le norme precedenti consentivano di chiarire quali valori dovrebbero orientare l'uso dell'IA e come tali valori possano essere incorporati nei sistemi tecnici, la 42001 affronta il problema più complesso della sostenibilità organizzativa di queste scelte. La norma assume che l'etica e la responsabilità dell'IA non possano essere affidate a iniziative episodiche, a comitati isolati o a buone intenzioni individuali, ma debbano essere istituzionalizzate all'interno di un sistema di gestione dotato di ruoli,

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



processi, controlli e meccanismi di miglioramento continuo. In questo senso, la governance dell'IA viene trattata come una funzione manageriale a pieno titolo, soggetta agli stessi criteri di pianificazione, attuazione, verifica e riesame che caratterizzano gli altri sistemi di gestione maturi. L'analisi del contesto e delle parti interessate, richiesta dalla norma, assume nel caso dell'IA una profondità particolare. I sistemi di IA operano infatti in ambienti socio-tecnici complessi, nei quali le aspettative degli stakeholder non sono sempre esplicite né allineate. La ISO/IEC 42001 invita le organizzazioni a interrogarsi non solo sugli obiettivi interni, ma anche sugli impatti esterni delle proprie soluzioni di IA, riconoscendo che la legittimità dell'uso dell'IA dipende dalla capacità di comprendere e bilanciare interessi spesso divergenti. In questa fase, la governance dell'IA si configura come un esercizio di responsabilità anticipatoria, nel quale l'organizzazione è chiamata a esplicitare le proprie assunzioni, a valutare i contesti di applicazione e a riconoscere i limiti entro cui l'automazione decisionale può essere considerata accettabile. La gestione del rischio rappresenta uno degli assi portanti dello standard. La ISO/IEC 42001 non riduce il rischio dell'IA a una dimensione tecnica, ma lo interpreta come fenomeno multidimensionale che include rischi etici, legali, reputazionali, operativi e strategici. In questa prospettiva, la valutazione del rischio non si limita a identificare scenari di malfunzionamento, ma

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



include l'analisi degli impatti potenziali sugli individui e sulla società, nonché delle conseguenze derivanti da un uso improprio o non previsto dei sistemi. Il trattamento del rischio diventa così un processo continuo, che accompagna l'intero ciclo di vita dell'IA e che richiede decisioni informate, documentate e periodicamente riesaminate. La norma introduce una logica di governo del rischio che si discosta dalla tradizionale gestione IT, riconoscendo la specificità dei sistemi adattivi e probabilistici. La definizione di ruoli e responsabilità costituisce un altro elemento distintivo della ISO/IEC 42001. La norma richiede che l'organizzazione chiarisca chi è responsabile di cosa lungo la catena decisionale dell'IA, superando l'ambiguità che spesso caratterizza i sistemi automatizzati. In contesti in cui le decisioni emergono dall'interazione tra modelli, dati e processi organizzativi, l'accountability non può essere data per scontata. La ISO/IEC 42001 impone di rendere esplicita la distribuzione delle responsabilità, attribuendo ruoli chiari per la supervisione, il controllo e l'intervento umano. Questo aspetto assume una rilevanza particolare anche dal punto di vista giuridico, poiché contribuisce a colmare il divario tra responsabilità formale e responsabilità sostanziale, rendendo più solido il presidio dell'IA nei confronti delle autorità e degli stakeholder. I controlli su dati, modelli e processi decisionali rappresentano il cuore operativo del sistema di gestione. La norma riconosce che la qualità dell'IA dipende in larga misura

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



dalla qualità dei dati e dalla coerenza dei processi che li trasformano in decisioni. Tuttavia, invece di prescrivere soluzioni tecniche specifiche, la ISO/IEC 42001 adotta un approccio basato sui controlli, richiedendo che l'organizzazione definisca, implementi e mantenga misure adeguate in funzione del contesto e del rischio. Questo approccio consente di adattare il sistema di gestione a tecnologie diverse e in rapida evoluzione, evitando l'obsolescenza normativa. Dal punto di vista normotecnico, la norma privilegia la verificabilità dei processi rispetto alla standardizzazione delle soluzioni, rendendo possibile l'audit senza irrigidire l'innovazione. Il monitoraggio continuo e il miglioramento rappresentano l'elemento che conferisce alla ISO/IEC 42001 una dimensione temporale esplicita. I sistemi di IA non sono statici: cambiano con i dati, con gli usi e con i contesti. La norma riconosce che una governance efficace non può essere episodica, ma deve essere sostenuta nel tempo attraverso meccanismi di osservazione, valutazione e revisione. In questa logica, il sistema di gestione dell'IA diventa un dispositivo di apprendimento organizzativo, capace di adattarsi ai cambiamenti tecnologici e normativi senza perdere coerenza. Il miglioramento continuo non è inteso come ottimizzazione delle performance algoritmiche, ma come rafforzamento progressivo della capacità dell'organizzazione di governare l'IA in modo responsabile. Uno degli aspetti più rilevanti della ISO/IEC 42001 è la sua



auditabilità. La possibilità di sottoporre il sistema di gestione a verifiche indipendenti rappresenta un elemento di discontinuità rispetto agli approcci precedenti alla governance dell'IA. L'audit consente di trasformare dichiarazioni di principio e policy interne in evidenze verificabili, rendendo la governance dell'IA osservabile dall'esterno. In questo senso, la certificazione non costituisce una garanzia assoluta di bontà dei sistemi di IA, ma attesta la maturità organizzativa nel governarli. Per auditor, giuristi e autorità di controllo, la ISO/IEC 42001 fornisce un linguaggio comune e una struttura di riferimento che facilita la valutazione della diligenza organizzativa. La relazione tra la ISO/IEC 42001 e la conformità normativa, in particolare rispetto al quadro europeo, è di natura strategica. Pur non essendo uno strumento giuridico, lo standard offre un supporto concreto alla dimostrazione di conformità ai requisiti regolatori, poiché traduce obblighi legali spesso formulati in termini generali in processi organizzativi strutturati. In un contesto in cui la regolamentazione dell'IA è destinata a evolvere rapidamente, la capacità di dimostrare un approccio sistemico alla governance diventa un fattore di resilienza normativa. La ISO/IEC 42001 consente alle organizzazioni di passare da una compliance reattiva a una compliance progettata, riducendo il rischio di interventi correttivi tardivi e costosi. Nel quadro complessivo del paper, la ISO/IEC 42001 può essere letta come il punto di convergenza tra etica, tecnica

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



e diritto. Essa non sostituisce la riflessione etica né la regolamentazione giuridica, ma fornisce l'infrastruttura organizzativa che consente di renderle operative e sostenibili. In una prospettiva ispirata alla filosofia delle tecnologie, la norma riconosce che il vero oggetto della governance non è l'algoritmo in sé, ma l'ecosistema decisionale che lo circonda. Governare l'IA significa governare le condizioni entro cui essa opera, le responsabilità che ne derivano e i valori che essa incarna. La ISO/IEC 42001 rappresenta oggi lo strumento più maturo per affrontare questa sfida, trasformando la governance dell'Intelligenza Artificiale da aspirazione teorica a pratica organizzativa strutturata e verificabile.

AI Act dell'Unione Europea – Regolamentazione cogente

Il Regolamento europeo sull'Intelligenza Artificiale, comunemente noto come AI Act⁸, rappresenta il primo tentativo sistematico, a livello sovranazionale, di tradurre in obblighi giuridici vincolanti le preoccupazioni etiche, sociali e di sicurezza emerse con la diffusione pervasiva dei sistemi di IA. La sua rilevanza non risiede unicamente nel contenuto prescrittivo, ma nella scelta di fondo che lo ispira: riconoscere l'Intelligenza

⁸ European Union. (2024). *Regulation (EU) 2024/1689 of the European Parliament and of the Council laying down harmonised rules on artificial intelligence (Artificial Intelligence Act)*. Official Journal of the European Union.



Artificiale come infrastruttura regolabile in quanto tale, e non come semplice estensione di tecnologie digitali preesistenti. In questo senso, l'AI Act segna un passaggio epistemico analogo a quello che, in ambito normotecnico, ha condotto allo sviluppo di standard di sistema come la ISO/IEC 42001. Entrambi condividono l'assunto secondo cui l'IA non può essere governata efficacemente attraverso interventi puntuali o correttivi ex post, ma richiede un impianto strutturato, capace di agire sul contesto organizzativo, sui processi decisionali e sulle responsabilità che ne derivano. L'impostazione risk-based adottata dal legislatore europeo costituisce il cuore concettuale del Regolamento. L'AI Act non mira a disciplinare in modo uniforme tutti i sistemi di IA, ma introduce una classificazione graduata basata sul livello di rischio che tali sistemi pongono ai diritti fondamentali, alla sicurezza e agli interessi pubblici. Questa scelta riflette una comprensione sofisticata della natura dell'IA come tecnologia general purpose, i cui effetti dipendono in larga misura dal contesto di applicazione. Tuttavia, la classificazione del rischio non è un esercizio meramente tecnico, bensì un atto normativo che incorpora valutazioni di ordine etico e politico. Stabilire che un sistema di IA sia "ad alto rischio" significa riconoscere che esso opera in ambiti in cui l'automazione decisionale può incidere in modo significativo sulla vita delle persone, rendendo necessarie garanzie rafforzate. In questa prospettiva, il rischio diventa una

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



categoria di mediazione tra etica e diritto, analoga a quella che, nei sistemi di gestione, consente di tradurre valori e principi in controlli organizzativi. Per i sistemi classificati come ad alto rischio, l'AI Act introduce un insieme articolato di obblighi che riguardano l'intero ciclo di vita dell'IA, dalla progettazione all'uso operativo. Tra questi figurano la gestione documentata del rischio, la qualità e la governance dei dati, la tracciabilità delle operazioni, la supervisione umana, la robustezza tecnica e la sicurezza informatica. Questi requisiti, pur formulati in termini giuridici, presentano una struttura sorprendentemente affine a quella dei sistemi di gestione normati in ambito ISO. Essi presuppongono infatti l'esistenza di processi organizzativi stabili, di ruoli chiaramente definiti e di meccanismi di controllo e monitoraggio continui. In assenza di tali elementi, la conformità al Regolamento rischia di rimanere puramente formale, affidata a documentazioni ad hoc o a soluzioni emergenziali, difficilmente sostenibili nel tempo. È proprio in questo punto che emerge con maggiore chiarezza la complementarità strutturale tra l'AI Act e la ISO/IEC 42001. Il Regolamento stabilisce ciò che deve essere garantito in termini di tutela dei diritti e di gestione del rischio, ma non entra nel dettaglio delle architetture organizzative necessarie per assicurare tali garanzie in modo sistematico. La ISO/IEC 42001, dal canto suo, non ha valore cogente, ma fornisce un modello di sistema di gestione che consente di rendere operativi e verificabili requisiti

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



che il legislatore formula in termini generali. In questa relazione, la norma tecnica non si pone come alternativa al diritto, ma come infrastruttura abilitante della conformità giuridica. Dal punto di vista della filosofia delle tecnologie, l'AI Act può essere interpretato come un tentativo di ricondurre l'IA entro un perimetro di governabilità democratica, riconoscendo che l'automazione decisionale non è un fatto neutro, ma una forma di potere che deve essere sottoposta a controllo. Tuttavia, il controllo giuridico, da solo, non è sufficiente a garantire un uso responsabile dell'IA, soprattutto in contesti organizzativi complessi. Il diritto può stabilire limiti e obblighi, ma non può sostituirsi alla capacità delle organizzazioni di comprendere e governare i propri sistemi. In questo senso, la governance dell'IA emerge come spazio intermedio tra norma giuridica e pratica tecnica, nel quale i sistemi di gestione assumono un ruolo centrale. Un aspetto particolarmente rilevante dell'AI Act riguarda la nozione di supervisione umana. Il Regolamento richiede che i sistemi di IA ad alto rischio siano progettati e utilizzati in modo tale da consentire un intervento umano significativo. Questa prescrizione, apparentemente semplice, solleva interrogativi complessi sul ruolo dell'essere umano nei sistemi automatizzati. La supervisione non può essere ridotta a un controllo simbolico o a una mera possibilità teorica di intervento, ma deve essere integrata nei processi decisionali in modo concreto ed efficace. Ciò implica una riflessione



organizzativa sulle competenze, sulle responsabilità e sulle condizioni operative necessarie affinché l'intervento umano sia realmente possibile. Ancora una volta, il Regolamento indica il fine, ma lascia aperta la questione dei mezzi, che devono essere definiti attraverso strumenti normotecnici adeguati. La tracciabilità e la documentazione, anch'esse richieste dall'AI Act, rappresentano un ulteriore punto di contatto con la logica dei sistemi di gestione. Rendere tracciabili le decisioni algoritmiche significa rendere osservabile il funzionamento di sistemi che, per loro natura, tendono all'opacità. Tuttavia, la tracciabilità non è una proprietà intrinseca degli algoritmi, ma il risultato di scelte organizzative relative alla documentazione, alla conservazione delle informazioni e alla definizione di responsabilità. In questo senso, l'AI Act presuppone implicitamente l'esistenza di un sistema organizzativo maturo, capace di sostenere nel tempo gli obblighi di trasparenza e accountability che esso introduce. La dimensione sanzionatoria del Regolamento, spesso enfatizzata nel dibattito pubblico, non deve essere letta esclusivamente come strumento punitivo, ma come elemento di rafforzamento della responsabilità organizzativa. Le sanzioni previste dall'AI Act mirano a rendere credibili gli obblighi introdotti, ma la loro efficacia dipende in larga misura dalla capacità delle organizzazioni di prevenire le non conformità attraverso un governo strutturato dell'IA. In questa prospettiva, la

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



conformità normativa non è un evento, ma un processo continuo che richiede monitoraggio, riesame e miglioramento. La ISO/IEC 42001 offre una risposta concreta a questa esigenza, fornendo un modello di governance che consente di integrare la compliance nel funzionamento ordinario dell'organizzazione. Un ulteriore elemento di riflessione riguarda il rapporto tra l'AI Act e l'innovazione. Una delle critiche più frequenti al Regolamento è il rischio di frenare lo sviluppo tecnologico attraverso un eccesso di vincoli. Tuttavia, questa lettura presuppone una contrapposizione tra innovazione e regolazione che non tiene conto della complessità dei sistemi socio-tecnici. L'assenza di governance non accelera l'innovazione, ma ne aumenta l'incertezza e i costi nel medio-lungo periodo. In questo senso, l'AI Act, se integrato con strumenti normotecnici adeguati, può contribuire a creare un ambiente di fiducia che favorisca un'innovazione sostenibile. I sistemi di gestione, lungi dall'essere meri adempimenti burocratici, possono diventare dispositivi di apprendimento organizzativo, capaci di accompagnare l'evoluzione tecnologica senza perdere il controllo. Nel quadro complessivo della governance dell'Intelligenza Artificiale, l'AI Act può dunque essere interpretato come il livello giuridico di un'architettura più ampia, che include dimensioni etiche, tecniche e organizzative. Esso stabilisce i confini entro cui l'IA può essere utilizzata legittimamente, ma lascia alle organizzazioni la

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



responsabilità di costruire i meccanismi interni necessari per rispettare tali confini in modo sostanziale. In questa responsabilità si colloca il ruolo centrale degli standard ISO/IEC, e in particolare della ISO/IEC 42001, come strumenti di traduzione tra obbligo legale e pratica organizzativa. Da una prospettiva ispirata alla filosofia delle tecnologie, la vera sfida posta dall'AI Act non è semplicemente quella di evitare sanzioni, ma di ripensare il rapporto tra tecnologia, organizzazione e responsabilità. L'IA non è un oggetto che può essere regolato dall'esterno senza modificare le strutture che la producono e la utilizzano. Governare l'IA significa governare le condizioni della sua possibilità, rendendo visibili e discutibili le scelte che essa incorpora. In questo senso, l'AI Act e la ISO/IEC 42001 non rappresentano due percorsi alternativi, ma due livelli di uno stesso progetto di governabilità democratica della tecnologia, nel quale il diritto definisce i limiti e la normazione tecnica costruisce le infrastrutture organizzative per rispettarli. È in questa integrazione che si gioca la possibilità di un'Intelligenza Artificiale non solo conforme, ma legittima, affidabile e socialmente sostenibile.

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



Confronto strutturato tra i quattro strumenti

Aspetto	ISO 26000	ISO/IEC 24368	ISO/IEC 42001	AI Act
Natura	Linea guida	Norma tecnica	Norma di sistema	Regolamento
Certificabile	No	No	Sì	No
Focus	Etica e responsabilità	Etica by design	Governance IA	Conformità legale
Approccio	Valoriale	Tecnico-etico	Gestionale	Giuridico
Obbligatorietà	Volontaria	Volontaria	Volontaria	Cogente
Ruolo	Fondamento culturale	Implementazione etica	Controllo e audit	Enforcement

FONDAZIONE
 ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
 Iscritto RUNTS Regione Lombardia al n. 1371/2024
 Iscritto ANAGRAFE NAZIONALE delle RICERCHE
 Ministero delle Università e della Ricerca con il cod. 002092_ETER
 Via Giuseppe Revere, 16
 20123 Milano
www.enia.ai
enia.ai@enia.ai



Integrazione con altri schemi sull'IA

Il Regolamento europeo sull'Intelligenza Artificiale, noto come AI Act, rappresenta il primo tentativo compiuto di affrontare l'Intelligenza Artificiale come oggetto giuridico sistemico, riconoscendone esplicitamente la natura di infrastruttura decisionale ad alto impatto sociale. La sua portata non può essere compresa se ridotta a un insieme di obblighi settoriali o a un mero apparato sanzionatorio; l'AI Act introduce piuttosto una nuova grammatica regolatoria, nella quale il rischio diventa la categoria cardine per governare la relazione tra automazione, diritti fondamentali e responsabilità organizzativa. In questo senso, il Regolamento si colloca pienamente all'interno di una visione della tecnologia come ambiente informazionale, nel quale le decisioni algoritmiche non sono eventi isolati, ma componenti strutturali di sistemi socio-tecnici complessi. L'IA, così intesa, non è semplicemente utilizzata dalle organizzazioni, ma ne riorganizza i processi cognitivi, redistribuendo capacità decisionali, potere e accountability lungo catene spesso opache e distribuite. L'impostazione risk-based adottata dal legislatore europeo costituisce una risposta esplicita a questa complessità. Classificando i sistemi di IA in base al livello di rischio che essi pongono per i diritti e la sicurezza delle persone, l'AI Act riconosce che non esiste un'Intelligenza Artificiale

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



“in astratto”, ma solo applicazioni situate, il cui impatto dipende dal contesto d’uso, dalla funzione svolta e dalla posizione che occupano all’interno dei processi decisionali. Tale classificazione non è neutrale, poiché incorpora una valutazione normativa su quali ambiti della vita sociale debbano essere maggiormente protetti dall’automazione incontrollata. La distinzione tra rischio inaccettabile, alto rischio, rischio limitato e rischio minimo riflette una scelta politica nel senso più alto del termine: stabilire dove l’efficienza algoritmica deve cedere il passo alla tutela della dignità umana e dove, invece, l’innovazione può essere lasciata a una maggiore libertà sperimentale. Per i sistemi classificati come ad alto rischio, l’AI Act introduce un insieme articolato di requisiti che, se letti attentamente, delineano implicitamente un modello di governance organizzativa. La gestione documentata del rischio, la qualità e la governance dei dati, la tracciabilità delle operazioni, la supervisione umana, la robustezza tecnica e la sicurezza informatica non sono obblighi che possano essere soddisfatti attraverso interventi puntuali o soluzioni tecniche isolate. Essi presuppongono l’esistenza di processi strutturati, di ruoli chiaramente definiti, di responsabilità formalizzate e di meccanismi di controllo e riesame continui. In altri termini, il Regolamento, pur non utilizzando il linguaggio dei sistemi di gestione, richiede alle organizzazioni di comportarsi come se tali sistemi fossero già in essere. È in questa tensione tra obbligo

FONDAZIONE
ENTE NAZIONALE per L’INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



giuridico e capacità organizzativa che emerge con particolare forza la rilevanza degli standard normotecnici, e in particolare della ISO/IEC 42001. L'AI Act definisce ciò che deve essere garantito in termini di tutela e controllo, ma lascia volutamente aperta la questione del come tali garanzie debbano essere implementate in modo sostenibile e verificabile. Questa scelta riflette la consapevolezza che il diritto, da solo, non può prescrivere architetture organizzative senza rischiare un'eccessiva rigidità o una rapida obsolescenza normativa. La conseguenza è che la conformità all'AI Act non può essere ridotta a un esercizio di interpretazione legale, ma richiede una capacità di governo interno che solo un sistema di gestione strutturato può offrire. La nozione di supervisione umana, centrale nel Regolamento, costituisce un esempio emblematico di questa dinamica. Richiedere che un sistema di IA sia soggetto a supervisione umana significativa implica interrogarsi su chi eserciti tale supervisione, con quali competenze, in quali momenti del processo decisionale e con quali poteri di intervento. Senza una chiara definizione di ruoli, responsabilità e procedure, la supervisione rischia di rimanere un concetto puramente formale, privo di efficacia reale. L'AI Act individua l'esigenza, ma non può, per sua natura, entrare nel dettaglio delle soluzioni organizzative. È qui che la normazione tecnica diventa indispensabile per trasformare un principio giuridico in una pratica operativa. Analoga considerazione vale per la

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



tracciabilità e la documentazione dei sistemi di IA. Il Regolamento richiede che le decisioni algoritmiche siano ricostruibili e comprensibili a posteriori, soprattutto nei casi in cui incidono sui diritti delle persone. Tuttavia, la tracciabilità non è una proprietà intrinseca degli algoritmi, ma il risultato di scelte organizzative che riguardano la gestione dei dati, la documentazione dei modelli, la conservazione delle informazioni e la definizione delle responsabilità. Senza un'infrastruttura organizzativa adeguata, la tracciabilità rimane un obiettivo irraggiungibile o eccessivamente oneroso. Ancora una volta, il Regolamento presuppone implicitamente l'esistenza di un sistema di gestione capace di sostenere tali obblighi nel tempo. Dal punto di vista della filosofia delle tecnologie, l'AI Act può essere interpretato come un tentativo di rendere l'automazione decisionale compatibile con i principi dello Stato di diritto. L'IA, in quanto tecnologia che media l'accesso a risorse, opportunità e diritti, esercita una forma di potere che deve essere sottoposta a controllo democratico. Tuttavia, questo controllo non può essere esercitato esclusivamente dall'esterno, attraverso sanzioni o divieti, ma deve essere interiorizzato dalle organizzazioni che sviluppano e utilizzano l'IA. In questa prospettiva, la governance non è un vincolo imposto dall'alto, ma una condizione di legittimità dell'uso della tecnologia. La dimensione sanzionatoria dell'AI Act, spesso enfatizzata nel dibattito pubblico, va letta in questa chiave. Le sanzioni non



rappresentano il fine ultimo del Regolamento, ma uno strumento per incentivare l'adozione di pratiche di governo responsabile. La vera sfida per le organizzazioni non è evitare la sanzione in sé, ma costruire una capacità strutturale di conformità che renda la non conformità un'eccezione, e non la regola. Questo richiede un passaggio da una logica reattiva a una logica progettuale della compliance, nella quale gli obblighi normativi vengono integrati nei processi ordinari di gestione. In questo senso, l'AI Act e la ISO/IEC 42001 possono essere letti come due livelli complementari di un'unica architettura di governabilità dell'IA. Il Regolamento definisce il perimetro giuridico entro cui l'IA può essere utilizzata legittimamente, mentre lo standard di sistema fornisce l'infrastruttura organizzativa necessaria per abitare quel perimetro in modo sostenibile. L'uno senza l'altro risulta incompleto: il diritto senza sistemi di gestione rischia di rimanere inattuato, mentre i sistemi di gestione senza un ancoraggio giuridico rischiano di perdere legittimità. Nel quadro complessivo della governance dell'Intelligenza Artificiale, l'AI Act non rappresenta quindi un punto di arrivo, ma un punto di cristallizzazione di un processo più ampio, nel quale etica, tecnica e diritto convergono nella costruzione di un nuovo paradigma di responsabilità tecnologica. Governare l'IA significa governare le condizioni della sua possibilità, rendendo visibili, discutibili e controllabili le scelte che essa incorpora. In questa prospettiva, l'AI Act

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



non si limita a dire ciò che è vietato o consentito, ma invita implicitamente le organizzazioni a dotarsi di strutture di governo adeguate alla complessità della tecnologia che utilizzano. È in questa integrazione tra obbligo giuridico e normazione tecnica che si gioca la possibilità di un'Intelligenza Artificiale non solo conforme, ma legittima, affidabile e socialmente sostenibile, coerente con i valori fondamentali dell'ordinamento europeo e con le aspettative di una società sempre più consapevole del potere insito nelle infrastrutture algoritmiche. L'audit dei sistemi di Intelligenza Artificiale rappresenta il punto di emersione concreta della governance dell'IA, ovvero il momento in cui principi etici, requisiti normativi e scelte organizzative cessano di essere dichiarazioni di intenti e diventano oggetti di verifica indipendente. In un contesto caratterizzato da elevata complessità tecnologica e da un crescente livello di rischio etico, giuridico e reputazionale, l'audit non svolge una funzione meramente ispettiva, ma assume il ruolo di dispositivo epistemico, capace di rendere osservabile ciò che, nei sistemi algoritmici, tende strutturalmente all'opacità. Auditare l'IA significa interrogare non solo i risultati prodotti dai modelli, ma l'insieme delle condizioni che ne rendono possibile il funzionamento: i processi decisionali, la qualità e la provenienza dei dati, le assunzioni progettuali, le modalità di supervisione umana e i meccanismi di controllo adottati dall'organizzazione. In questa prospettiva, l'audit

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



dell'IA non è riducibile a una verifica tecnica del codice o delle performance, ma si configura come una valutazione sistematica e indipendente dell'ecosistema socio-tecnico in cui l'IA è inserita. La pratica dell'audit IA riflette la natura multilivello della governance dell'Intelligenza Artificiale. Essa può essere condotta a fini interni, come strumento di autovalutazione e miglioramento continuo, a fini di seconda parte, per valutare fornitori e partner lungo la catena del valore digitale, oppure a fini di terza parte, nell'ambito di processi di certificazione. In tutti i casi, l'audit opera come meccanismo di traduzione tra linguaggi diversi: rende leggibili per auditor e autorità ciò che nasce in contesti tecnici altamente specializzati, e consente ai decisori organizzativi di comprendere il livello reale di controllo esercitato sui sistemi di IA. Questo ruolo di mediazione è particolarmente rilevante in un dominio in cui la distanza tra chi progetta, chi governa e chi subisce gli effetti delle decisioni automatizzate può essere significativa. Gli ambiti tipicamente oggetto di audit nei sistemi di IA riflettono le principali dimensioni del rischio algoritmico. La governance e l'accountability vengono esaminate per verificare se le responsabilità siano chiaramente definite e se esistano meccanismi efficaci di supervisione e intervento umano. La gestione del rischio IA viene valutata in termini di capacità dell'organizzazione di identificare, analizzare e trattare i rischi lungo l'intero ciclo di vita dei sistemi, evitando approcci

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



statici o meramente reattivi. La qualità e la provenienza dei dati diventano oggetto di scrutinio non solo per ragioni tecniche, ma per le implicazioni etiche e legali che esse comportano, in particolare rispetto a bias, discriminazioni e violazioni dei diritti fondamentali. La tracciabilità e la documentazione consentono di ricostruire le decisioni algoritmiche a posteriori, trasformando l'IA da “scatola nera” a processo almeno parzialmente intelligibile e contestualizzabile. Infine, la conformità ai requisiti regolatori, in particolare a quelli introdotti dall'AI Act, rappresenta un elemento centrale della verifica, soprattutto per i sistemi classificati come ad alto rischio. In questo scenario, la ISO/IEC 42001 assume un ruolo centrale come strumento di riferimento per l'audit e la certificazione dei sistemi di gestione dell'Intelligenza Artificiale. La norma non valuta il singolo algoritmo né pretende di certificare la “bontà” intrinseca di una soluzione tecnica, ma attesta la capacità dell'organizzazione di governare l'IA in modo strutturato, responsabile e coerente nel tempo. La certificazione secondo la ISO/IEC 42001 segnala che l'organizzazione ha implementato processi di analisi del contesto, gestione del rischio, definizione delle responsabilità, controllo dei dati e dei modelli, monitoraggio continuo e miglioramento sistematico. In questo senso, la certificazione non è un sigillo di infallibilità tecnologica, ma un indicatore di maturità organizzativa. La distinzione tra valutazione del singolo

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



algoritmo e valutazione del sistema di gestione è cruciale per comprendere il significato della certificazione nell'ambito dell'IA. I sistemi algoritmici sono dinamici, adattivi e fortemente dipendenti dal contesto; pretenderne una certificazione statica equivarrebbe a ignorarne la natura evolutiva. La ISO/IEC 42001 affronta questa complessità spostando l'attenzione dal prodotto al processo, riconoscendo che la responsabilità dell'IA risiede nella capacità dell'organizzazione di controllare le condizioni entro cui i modelli operano e producono effetti. Questa impostazione risulta particolarmente coerente con l'approccio risk-based dell'AI Act, che richiede non tanto la perfezione tecnica, quanto la dimostrazione di un controllo adeguato e proporzionato ai rischi. Sebbene il Regolamento europeo non preveda una certificazione obbligatoria di tipo ISO, l'adozione di un sistema di gestione conforme alla ISO/IEC 42001 facilita in modo significativo la dimostrazione di conformità ai requisiti normativi. In un contesto regolatorio in rapida evoluzione, la capacità di esibire evidenze strutturate di governance, auditabilità e miglioramento continuo rappresenta un fattore di resilienza giuridica e organizzativa. Audit strutturati e certificazioni volontarie diventano così strumenti di supporto alla compliance, non in senso riduttivo, ma come leve per ridurre l'incertezza normativa e il rischio sanzionatorio, rafforzando al contempo la fiducia degli stakeholder. La governance e l'audit dell'Intelligenza Artificiale richiedono

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



inevitabilmente competenze multidisciplinari. Nessuna singola figura professionale è in grado di presidiare da sola la complessità dei sistemi di IA, che si collocano all'intersezione tra tecnologia, diritto, etica e management. La responsabilità della governance dell'IA si distribuisce tra ruoli che includono la definizione strategica, la gestione del rischio, la supervisione etica, la tutela dei dati personali, la progettazione tecnica e il controllo indipendente. Tuttavia, questa distribuzione non deve essere confusa con una diluizione dell'accountability. Al contrario, la chiarezza dei ruoli e la capacità di coordinamento rappresentano una condizione essenziale affinché l'audit e la certificazione possano avere un significato sostanziale e non puramente formale. In ultima istanza, la responsabilità ultima ricade sul top management, chiamato a garantire che l'adozione dell'IA sia coerente con i valori, gli obiettivi e gli obblighi dell'organizzazione. Nel quadro complessivo delineato da questo paper, emerge con chiarezza come la gestione etica dell'Intelligenza Artificiale non possa essere affidata a un singolo standard o a un unico livello di regolazione. Gli standard internazionali offrono strumenti complementari che, se integrati, consentono di costruire una governance multilivello dell'IA. La ISO 26000 fornisce il fondamento etico e valoriale, chiarendo come un'organizzazione dovrebbe decidere, usare e controllare l'IA in modo responsabile. La ISO/IEC 24368 traduce tali valori in criteri operativi per la

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



progettazione e lo sviluppo dei sistemi. La ISO/IEC 42001 struttura queste scelte all'interno di un sistema di gestione auditabile e certificabile. L'AI Act, infine, stabilisce il perimetro giuridico entro cui tali pratiche devono collocarsi. La governance dell'Intelligenza Artificiale, così intesa, non è un esercizio teorico né un adempimento burocratico, ma una necessità concreta per organizzazioni che operano in contesti ad alta complessità e responsabilità. L'adozione di un approccio integrato, fondato su standard internazionali e regolamentazione, consente di trasformare l'IA da fonte di rischio opaco a infrastruttura decisionale governabile. In questa trasformazione si gioca non solo la conformità normativa, ma la legittimità sociale dell'Intelligenza Artificiale come tecnologia capace di contribuire a uno sviluppo sostenibile, responsabile e coerente con i valori fondamentali delle società democratiche. È su questo terreno che la governance dell'IA diventa una forma avanzata di responsabilità organizzativa, e che l'audit e la certificazione cessano di essere strumenti di controllo ex post per diventare dispositivi di fiducia, orientamento e apprendimento collettivo.

FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai



FONDAZIONE
ENTE NAZIONALE per L'INTELLIGENZA ARTIFICIALE ENIA®
Iscritto RUNTS Regione Lombardia al n. 1371/2024
Iscritto ANAGRAFE NAZIONALE delle RICERCHE
Ministero delle Università e della Ricerca con il cod. 002092_ETER
Via Giuseppe Revere, 16
20123 Milano
www.enia.ai
enia.ai@enia.ai